

PRUEBA TÉCNICA · CIBERSEGURIDAD

Detección y Respuesta a Incidentes

NIST SP 800-61 · MITRE ATT&CK v14 · Ley 1581

PREPARADO POR	Lady Marcela Romero Rivero
ROL	Líder de Ciberseguridad
CLIENTE	Simon Movilidad
ESCENARIO	FleetSec S.A.S. — Telemetría de flotas
FECHA	25 de agosto de 2026
VERSIÓN	1.0

CONFIDENCIAL — Exclusivo para Simon Movilidad

Tabla de contenido

0. Cronología reconstruida (a partir de los indicadores embebidos)

1. Contención — AWS CLI exacto (ejecutar de arriba a abajo)

Paso 1 — Revocar las credenciales del usuario IAM comprometido

Paso 2 — Revocar las sesiones STS ya emitidas (tokens robados)

Paso 3 — Revocar sesiones y aislar la EC2 comprometida (primero la evidencia)

Paso 4 — Preservar la evidencia de CloudTrail / S3 / Flow-Log (Write-Once)

Paso 5 — Bloquear la IP del atacante en el WAF + poner en cuarentena la tarea ECS maliciosa

2. Mapeo MITRE ATT&CK v14 (≥ 6 técnicas)

3. Análisis de Causa Raíz (5 Porqués + Queso Suizo)

4. Resumen ejecutivo para el CEO (≤ 1 página, sin jerga)

5. Plan de remediación posincidente (P1/P2/P3)

6. Ley 1581 — Notificación a la SIC (Colombia)

Framework: NIST SP 800-61r2 · **Severidad:** SEV-1 (exfiltración activa de datos, compromiso de admin) **Detección:** GuardDuty + CloudTrail · **Estado en T+02:00:** brecha activa ~2h · **PII involucrada:** Sí (Ley 1581)

La secuencia es innegociable: **preservar evidencia → contener → erradicar → recuperar → lecciones aprendidas.**

0. Cronología reconstruida (a partir de los indicadores embebidos)

UTC	Acción	Técnica
T+00:00	Inicio de sesión en consola desde <code>185.220.101.22</code> (Tor) como IAMUser	T1078.004
T+00:15	<code>CreateLoginProfile</code> en <code>svc-monitoring</code>	T1098
T+00:22	<code>AttachUserPolicy</code> AdministratorAccess → <code>svc-monitoring</code>	T1098.001 / T1548
T+00:35	387× <code>s3:GetObject</code> / 8 min sobre <code>fleetpay-prod-drivers</code> (45.7 GB)	T1530
T+00:58	12× <code>kms:Decrypt</code> sobre <code>prod-data-key</code>	T1530
T+01:10	10.0.2.45 → 185.220.101.22:443, 49 GB salientes	T1567.002
T+01:40	<code>RegisterTaskDefinition</code> con <code>docker.io/attacker/exfil:latest</code>	T1610
T+01:45	<code>DeleteTrail</code> — BLOQUEADO por SCP	T1562.008
T+01:50	GuardDuty <code>Trojan:EC2/DNSDataExfiltration</code> en i-0abc1234def56789	T1071.004

1. Contención — AWS CLI exacto (ejecutar de arriba a abajo)

Preserve la evidencia ANTES de cualquier cambio destructivo/de red. Nunca haga `stop` de una instancia antes de la adquisición de memoria. Todo comando es reversible donde se indica.

Paso 1 — Revocar las credenciales del usuario IAM comprometido

```
USER=svc-monitoring
# Inventory keys first (evidence)
aws iam list-access-keys --user-name "$USER" > ir-evidence/${USER}-keys.json
# Deactivate (preferred over delete – preserves for forensics)
for k in $(jq -r '.AccessKeyMetadata[].AccessKeyId' ir-evidence/${USER}-keys.json); do
  aws iam update-access-key --user-name "$USER" --access-key-id "$k" --status Inactive
done
# Kill console access (the attacker created a login profile at T+00:15)
aws iam delete-login-profile --user-name "$USER" || true
```

Rollback: reactivar las claves / recrear el login profile.

Paso 2 — Revocar las sesiones STS ya emitidas (tokens robados)

```
cat > /tmp/revoke.json <<'EOF'
{ "Version": "2012-10-17",
  "Statement": [{ "Effect": "Deny", "Action": "*", "Resource": "*",
    "Condition": { "DateLessThan": { "aws:TokenIssueTime": "2026-08-23T02:00:00Z" } } } ] }
EOF
aws iam put-user-policy --user-name svc-monitoring \
  --policy-name RevokeSessionsTokenIssueBefore --policy-document file:///tmp/revoke.json
# Also detach the illegitimately attached admin policy
aws iam detach-user-policy --user-name svc-monitoring \
  --policy-arn arn:aws:iam::aws:policy/AdministratorAccess
```

`aws:TokenIssueTime` es la forma canónica de invalidar de inmediato los tokens STS vivos.

Rollback: `aws iam delete-user-policy --user-name svc-monitoring --policy-name RevokeSessionsTokenIssueBefore`

Paso 3 — Revocar sesiones y aislar la EC2 comprometida (primero la evidencia)

```
INSTANCE_ID=i-0abc1234def56789
mkdir -p ir-evidence
# 3a. Snapshot every attached volume BEFORE touching the network
for vol in $(aws ec2 describe-instances --instance-ids $INSTANCE_ID \
  --query 'Reservations[].Instances[].BlockDeviceMappings[].Ebs.VolumeId' --output text); do
  aws ec2 create-snapshot --volume-id $vol \
    --description "Forensic $INSTANCE_ID $(date -u +%Y%m%dT%H%M%S)" \
    --tag-specifications 'ResourceType=snapshot,Tags=[{Key=ir-evidence,Value=true},
{Key=incident,Value=INC-2026-001}]'
done
# 3b. Memory acquisition BEFORE stop (RAM is lost on stop)
aws ssm send-command --document-name "AWS-RunShellScript" --instance-ids $INSTANCE_ID \
  --parameters 'commands=["insmod /opt/lime.ko path=/tmp/mem.lime format=lime || dd if=/dev/
mem of=/tmp/mem.raw"]'
# 3c. Isolate to a pre-created quarantine SG (no ingress, egress only to collector)
aws ec2 modify-instance-attribute --instance-id $INSTANCE_ID --groups sg-quarantine
```

Rollback: `aws ec2 modify-instance-attribute --instance-id $INSTANCE_ID --groups sg-app-original`

Paso 4 — Preservar la evidencia de CloudTrail / S3 / Flow-Log (Write-Once)

```
aws s3 cp s3://fleetsec-cloudtrail-logs/AWSLogs/<acct>/CloudTrail/us-east-1/2026/08/23/ \
  s3://fleetsec-logs-<acct>/INC-2026-001/cloudtrail/ --recursive # Object Lock COMPLIANCE
bucket
aws cloudtrail lookup-events \
  --lookup-attributes AttributeKey=Username,AttributeValue=svc-monitoring \
  --start-time 2026-08-23T00:00:00Z --end-time 2026-08-23T02:00:00Z > ir-evidence/svc-
monitoring-events.json
aws logs start-query --log-group-name /fleetsec/vpc/flowlogs \
  --start-time $(date -d '2026-08-23T01:00:00Z' +%s) --end-time $(date -d
'2026-08-23T02:00:00Z' +%s) \
  --query-string 'fields @timestamp, srcAddr, dstAddr, bytes | filter srcAddr like /
10.0.2.45/ | sort bytes desc'
```

Paso 5 — Bloquear la IP del atacante en el WAF + poner en cuarentena la tarea ECS maliciosa

```
# Add to WAF IP set (immediate edge block)
aws wafv2 update-ip-set --name blocklist-ir --scope REGIONAL --id $IPSET_ID \
  --addresses 185.220.101.22/32 --lock-token $(aws wafv2 get-ip-set --name blocklist-ir --
scope REGIONAL --id $IPSET_ID --query LockToken --output text)
# Stop & deregister the attacker task definition
aws ecs list-tasks --cluster fleetsec --query 'taskArns' --output text | tr '\t' '\n' | \
  while read t; do aws ecs stop-task --cluster fleetsec --task "$t" --reason "INC-2026-001
attacker image"; done
aws ecs deregister-task-definition --task-definition $(aws ecs list-task-definitions \
  --query "taskDefinitionArns[?contains(@,'exfil')][0]" --output text)
```

2. Mapeo MITRE ATT&CK v14 (≥6 técnicas)

ID de técnica	Nombre	Táctica	Manifestación aquí	Mitigación (D3FEND)
T1078.004	Valid Accounts: Cloud	Initial Access / Persistence	Inicio de sesión en consola desde Tor con credenciales IAM válidas	Imponer MFA (D3-MFA); acceso condicional; denegar Tor en el WAF
T1098 / T1098.001	Account Manipulation: Additional Cloud Creds	Persistence	CreateLoginProfile + asignación de admin en svc-monitoring	SCP que deniega modificaciones IAM a usuarios de servicio (D3-AM)
T1548	Abuse Elevation Control	Privilege Escalation	AttachUserPolicy AdministratorAccess	Línea base de mínimo privilegio; IAM Access Analyzer
T1530	Data from Cloud Storage	Collection	387× GetObject + 12× kms:Decrypt sobre datos de conductores	Bucket policy de S3 con condición de VPC-endpoint; grants de CMK
T1567.002	Exfiltration to Cloud/Web	Exfiltration	45.7 GB → 185.220.101.22:443	Firewall de salida de VPC / allowlist de NetFw (D3-OEC)
T1610	Deploy Container	Execution	RegisterTaskDefinition con imagen del atacante	Política de imágenes solo desde ECR; control de admisión sobre el origen de la imagen
T1562.008	Impair Defenses: Disable Cloud Logs	Defense Evasion	DeleteTrail (bloqueado por SCP)	SCP que deniega DeleteTrail (funcionó); alerta ante el intento
T1071.004	App Layer Protocol: DNS	C2 / Exfil	Exfiltración DNS de GuardDuty en i-0abc...	Route53 Resolver DNS Firewall

3. Análisis de Causa Raíz (5 Porqués + Queso Suizo)

5 Porqués 1. ¿Por qué se exfiltraron 45.7 GB de PII? svc-monitoring tenía AdministratorAccess. 2. ¿Por qué obtuvo admin? AttachUserPolicy tuvo éxito para un usuario de servicio. 3. ¿Por qué tuvo éxito? Ninguna SCP impedía la modificación IAM de usuarios de servicio por parte de principales que no son administradores de IAM. 4. ¿Por qué no existía esa SCP? La línea base de SCP de la organización nunca se revisó tras la migración de cuenta única → organización. 5. ¿Por qué nunca se revisó? No existía un proceso periódico de revisión de cumplimiento.

Causa raíz real: un proceso ausente (revisión periódica de controles), no solo una política ausente.

Queso suizo — capas que deberían haber detenido esto: - MFA en usuarios de consola IAM: no impuesta (el inicio de sesión desde Tor tuvo éxito) - Allowlist de IP/geo en la consola: no impuesta (el nodo de salida Tor alcanzó la consola) - SCP sobre modificaciones IAM a usuarios de servicio: ausente - GuardDuty UnauthorizedAccess: se activó — pero la reacción fue demasiado lenta (2h) - SCP sobre DeleteTrail: bloqueó la anti-forense - Firewall de salida de VPC: ausente (49 GB salieron sin impedimento) - Grants de CMK acotados a cargas de trabajo: svc-monitoring podía hacer Decrypt de prod-data-key

4. Resumen ejecutivo para el CEO (≤1 página, sin jerga)

Incidente INC-2026-001 — Informe de brecha de datos Para: CEO y equipo ejecutivo ·

De: Ingeniería de Seguridad · **Estado:** Contenido · **Fecha:** 2026-08-23

Qué ocurrió. Un atacante inició sesión a través de una red de anonimato usando las credenciales de una cuenta de servicio interna, otorgó a esa cuenta permisos completos de administrador y copió un gran volumen de datos de conductores fuera de nuestros sistemas durante aproximadamente dos horas antes de que cortáramos el acceso.

Qué se vio afectado. - Datos: datos personales de conductores (nombres, cédulas, placas de vehículos, posiciones GPS). - Escala aproximada: ~45.7 GB del almacén `fleetpay-prod-drivers`. - Duración: ~2 horas desde el primer acceso hasta la contención. - Sistemas: un servidor de procesamiento y un bucket de datos; el servicio principal permaneció en línea.

Impacto regulatorio. - **Ley 1581:** se requiere notificar a la SIC dentro de los **15 días hábiles** siguientes a la detección. Envío objetivo: **2026-09-12**. Los titulares de datos afectados probablemente requieran notificación directa (alto riesgo para sus derechos). - Conservar el registro del incidente durante al menos 5 años.

Tres acciones inmediatas. 1. Imponer MFA + bloquear redes de anonimato en todos los accesos de administración — SecOps, 48h. 2. Añadir barreras de protección para que a una cuenta de servicio nunca se le pueda otorgar admin — SecOps, 72h. 3. Activar controles de tráfico saliente para que no pueda salir data masiva — Redes, 7 días.

Impacto estimado. Directo (forense, legal, notificación) + exposición regulatoria de hasta **2.000 SMMVL** bajo la Ley 1581 + reputacional. El rango se afinará tras el alcance forense.

5. Plan de remediación posincidente (P1/P2/P3)

Prioridad	Ítem	Esfuerzo	Responsable	Vence
P1	SCP: denegar modificaciones IAM a usuarios svc-* por parte de principales que no son admin de IAM	1 d	SecOps	+3 d
P1	Imponer MFA + acceso condicional (bloquear Tor/geo) en todos los usuarios de consola IAM	2 d	SecOps+TI	+7 d
P1	Firewall de salida de VPC con allowlist de dominios (Network Firewall)	1 sem	Redes	+14 d
P1	Acotar los grants de claves KMS a los roles de carga de trabajo; eliminar Decrypt amplio	2 d	Plataforma	+7 d
P2	Migrar svc-monitoring a federación OIDC (sin claves estáticas)	2 sem	Plataforma	+30 d
P2	Política de imágenes solo desde ECR + control de admisión (bloquear docker.io/*)	1 sem	Plataforma	+30 d
P2	Desplegar las 4 reglas Sigma en el SIEM + paginado on-call	1 sem	SecOps	+21 d
P2	Ejercicio de simulación (tabletop) sobre este escenario exacto	0.5 d	SecOps	+30 d
P3	Proceso documentado y programado de revisión trimestral de SCP/controles	1 d	GRC	+60 d
P3	Route53 DNS Firewall para el TTP de exfiltración por DNS	3 d	Redes	+45 d

6. Ley 1581 — Notificación a la SIC (Colombia)

- **Plazo:** dentro de los 15 días hábiles siguientes a la detección (detección 2026-08-23 → antes del 2026-09-12).
- **Canal:** portal web de la SIC, formulario formal de notificación de incidentes.
- **Contenido:** naturaleza del incidente, categorías de PII afectadas (identificación, ubicación, placa), número aproximado de titulares de datos, contacto, medidas adoptadas/planificadas, posibles consecuencias.
- **Titulares de datos:** notificación directa (correo + aviso público) dado el alto riesgo.
- **Retención de registros:** ≥ 5 años.